

HTB ACADEMY

Introduction to Threat Hunting & Hunting With Elastic

HTB Academy · Module 214 · Threat Hunting Track · Walkthrough

A complete illustrated walkthrough of proactive threat hunting — the 8-stage hunting process, threat intel fundamentals, and a full end-to-end hunt for a real-feeling malware campaign (Stuxbot) using KQL in the Elastic Stack. Skills-assessment answers are partially masked as a hint.

Platform	HackTheBox Academy
Module	Intro to Threat Hunting & Hunting With Elastic (#214)
Completion	100% — all 6 sections
Analyst	Chayan Panchal · @tron874
Core Skills	Threat hunting lifecycle, KQL, Sysmon, MITRE ATT&CK, threat intel triage

1 Threat Hunting Fundamentals

The median dwell time for an attacker inside a network is measured in weeks — traditional reactive defenses only catch threats after they've already established persistence. Threat hunting closes that gap by proactively searching for attacker TTPs before an automated tool ever fires an alert.

NOTE Hunting is both **proactive** (hypothesis-driven, continuous) and **reactive** (IR-triggered, evidence-driven) — and it runs **simultaneously** with incident response: IR contains the known threat while hunters look for connected ones.

The 8-stage hunting process



Threat Hunting Lifecycle

1. SETTING THE STAGE

Plan targets, enable logging, configure SIEM/EDR/IDS, review intel

2. FORMULATE HYPOTHESES

Build testable predictions from intel, alerts, or intuition

3. DESIGN THE HUNT

Choose data sources, tools, IOCs; write custom queries

4. DATA GATHERING & EXAMINATION

Active collection and analysis – iterative, refine as you go

5. EVALUATE FINDINGS

Confirm or disprove the hypothesis; understand attacker behaviour

6. MITIGATE THREATS

Isolate, patch, remove malware, update configs

7. AFTER THE HUNT

Document findings, update intel platforms, refine detection rules

8. CONTINUOUS LEARNING

Each hunt improves the next – evolving TTPs need evolving methods

2 Glossary, Pyramid of Pain & Threat Intel Types

Level	Indicator type	Difficulty to change (attacker)
Top	TTPs	Tough — requires rebuilding the whole operation
2nd	Tools	Challenging — rewrite or replace tooling
3rd	Network/host artifacts	Annoying — adjust C2 comms, file paths
4th	Domain names	Simple — register a new domain
5th	IP addresses	Easy — switch IPs or use a proxy
Bottom	Hash values	Trivial — change one byte, new hash

KEY INSIGHT Hunt at the TTP level whenever possible — it forces the attacker to fundamentally change their approach, costing them the most time and resources.

Threat intelligence types

Type	Audience	Answers	Example
Strategic	C-suite, VPs	Who? Why?	APT28 targets governments for political espionage
Operational	Mid-management	How? Where?	REvil gains access via phishing, moves laterally via credential dumping
Tactical	SOC analysts, IR	What exactly?	Specific C2 IPs, file hashes, registry keys, mutex names

3 Hunting for Stuxbot — Threat Intel & IOCs

Field	Value
Actor	Stuxbot cybercrime group
Motive	Espionage — no ransomware or financial exfiltration observed
Initial access	Phishing email -> OneNote file -> embedded batch file -> PowerShell -> RAT
Platform	Microsoft Windows
Risk level	Critical

IOCs from the threat intel report	
OneNote file URLs	transfer.sh/get/kNxU7/invoice.one mega.io/dl9o1Dz/invoice.one
PowerShell staging	pastebin.com/raw/AvHtdKb2, /raw/gj58DKz
C2 nodes	91.90.213.14:443, 103.248.70.64:443, 141.98.6.59:443
SHA256 hashes	226A723F... C346077D... 018D37CB...

4 Hunt Sequence — KQL Queries & Findings

Each step below chains directly off the previous finding — this is the core discipline of hunting: follow the process tree, don't jump around.

Step	Goal	KQL	Finding
1	Find the OneNote download	event.code:15 AND file.name:*invoice.one	Downloaded via MSEdge on WS001 by user Bob
2	Confirm file creation on disk	event.code:11 AND file.name:invoice.one*	Zone.Identifier shows it came from the internet
3	Check DNS at time of download	dns.question.name:*	Query for file.io (hosting provider) found
4	Confirm OneNote opened it	event.code:1 AND process.command_line:*invoice.one*	OneNote.exe opened it 6s after download
5	Find OneNote's child processes	process.parent.name:"ONENOTE.EXE"	cmd.exe launched invoice.bat from temp
6	Find what invoice.bat launched	process.parent.command_line:*invoice.bat*	powershell.exe downloaded a script from Pastebin
7	Investigate the PowerShell PID	process.pid:"9944"	File drops, DNS for ngrok.io, C2, dropped default.exe
8	Check if default.exe ran	process.name:"default.exe"	Yes — C2 comms, dropped SharpHound.exe + svchost.exe
9	Check if SharpHound ran	process.name:"SharpHound.exe"	Ran twice — AD enumeration performed
10	Check the hash across all machines	process.hash.sha256:018d37cb...	Found on WS001 and PKI — lateral movement confirmed
11	Credential attacks from WS001?	(event.code:4624 OR 4625) AND LogonType:3	Failed admin logins, then successful svc-sql1 logins

5 Full Attack Timeline



Stuxbot — Reconstructed Timeline

- 1. MAR 26, 22:05**
invoice.one downloaded via MSEdge from file.io on WS001 (Bob)
- 2. MAR 26, 22:06**
OneNote opens it -> invoice.bat runs -> PowerShell stages from Pastebin
- 3. MAR 26 (cont.)**
PowerShell drops default.exe, connects to ngrok C2
- 4. MAR 26-27**
C2 activity continues – ngrok IP rotates
- 5. MAR 27**
default.exe executes; SharpHound.exe run twice (AD enumeration)
- 6. MAR 27 (cont.)**
svchost.exe, payload.exe, and a VBS file uploaded
- 7. MAR 27**
Mimikatz executed: lsadump::dcsync /domain:eagle.local /all /csv
- 8. MAR 27, 22:18**
default.exe found on the PKI server – lateral movement via PsExec
- 9. MAR 28**
Further successful logons from WS001 confirmed on a second host

Sysmon event IDs used to reconstruct it

Event ID	Description	Used for
1	Process creation	Track parent-child process chains
3	Network connection	Detect C2 connections
11	File create	Detect files dropped to disk
15	FileCreateStreamHash	Detect browser downloads (Zone.Identifier)
22	DNS query	Detect C2 domain resolution

6 Skills Assessment & Key Takeaways

Hunt	MITRE technique	Description
Hunt 1	T1570 — Lateral Tool Transfer	Tools copied to C:\Users\Public
Hunt 2	T1547.001 — Registry Run Keys	Persistence via registry autostart
Hunt 3	PowerShell Remoting	WinRM lateral movement toward the DC



Skills assessment answers (masked)

```
Hunt 1 answer -> s...s..1
Hunt 2 answer -> r.....a.....d
Hunt 3 answer -> w.....1
```

Key takeaways

Takeaway	Why it matters
Dwell time is the enemy	Proactive hunting is the answer — don't wait for alerts
Always follow the process chain	Download -> open -> child process -> network -> persistence -> lateral movement
Sysmon Event 15 = the download detector	FileCreateStreamHash is the go-to for browser downloads
Zone.Identifier means "from the internet"	Always worth flagging on an executable or script
ngrok is a common C2 masking technique	DNS queries for ngrok.io from internal hosts are suspicious
SharpHound = AD enumeration	= the attacker is preparing for privilege escalation
Hash-based hunting reveals blast radius	Search the same hash across every machine in the environment

7 Quick Reference — KQL & Sysmon



KQL & Sysmon quick reference

```
event.code:15 AND file.name:*.one           # browser download detection
event.code:11 AND file.name:...             # file creation on disk
event.code:1 AND process.parent.name:...    # child process of a given parent
process.hash.sha256:<hash>                  # hunt one hash across ALL machines
(event.code:4624 OR 4625) AND winlog.event_data.LogonType:3 # network logons
```

```
Sysmon 1  Process Create   Sysmon 11 File Create
Sysmon 3  Network Connect  Sysmon 15 FileCreateStreamHash (downloads)
Sysmon 22 DNS Query
```